



## Security Culture 2.0

Enrique Larios-Vargas  
Nick Miller

# Frontispiece

---

## Copyright and License

Copyright (c) 2026 The OWASP Foundation.

This work is licensed under a [Creative Commons Attribution-ShareAlike 4.0 International License](#). Please read and understand the license and copyright conditions.

## Leaders

- Enrique Larios-Vargas
- Nick Miller

## Collaborators

- Michael L. W. Vliek
- Nicolas Humblot

# SECUR-E Visualization Concepts

*Deliverable 5. Contains four visualization templates: the COM-B Profile Bar Chart, the Team Composition Overview, the Longitudinal Tracking template, and the Five Automated Insight Triggers.*

### Design rationale: table-native visualizations

All four visualizations in this deliverable are built entirely from Word table cells, using background shading, cell-width proportioning, and typographic emphasis. This is a deliberate choice, not a limitation. Table-native charts are editable, copyable, and portable; they do not break when documents are converted to PDF, printed, or shared across organizational boundaries. They also do not require specialist tools to customize or update.

The design principle is that the visual pattern produced by each table must be as information-rich as the chart type it replaces. A shaded band column communicates the same profile shape as a radar chart arm and is more precise because the band label eliminates ambiguity about which range is meant. A width-proportioned bar communicates the same distribution as a traditional bar chart and is directly editable when team data changes.

### Visualization 1: COM-B Profile Bar Chart

*The primary per-developer visualization, three columns (CAP, OPP, MOT), five band rows, filled from the bottom up to the active band.*

The COM-B Profile Bar Chart renders a developer's three-dimensional security profile as a vertical chart. Each of the three dimensions has its own column. The five band rows (Very Low at the bottom through Very High at the top) run the full height of the chart. Cells are filled from the bottom up to and including the active band: the active band cell receives the dimension's full color and displays the normalized score; cells below it receive progressively lighter shades of the same color; cells above it are ghost-white. This means the height of each colored column is a direct visual encoding of the score; a taller column means a higher score, in the same way as a standard bar chart rotated 90 degrees.

The visual distinction between the three dimensions uses the same color assignment across all five deliverables: CAP in deep blue, OPP in deep green, MOT in deep purple. A developer whose profile is heavily skewed toward one dimension, for instance, high MOT but low OPP, produces a chart with an obvious asymmetry between the purple and green columns, which is immediately visible even before reading the band labels.

**EXAMPLE A - Enthusiast profile** CAP: High (75) | OPP: Low (31) | MOT: High (81)

|           | CAP<br>High (75) | OPP<br>Low (31) | MOT<br>High (81) |
|-----------|------------------|-----------------|------------------|
| Very High |                  |                 |                  |
| High      | 75               |                 | 81               |
| Moderate  |                  |                 |                  |
| Low       |                  | 31              |                  |
| Very Low  |                  |                 |                  |

**EXAMPLE B - Unaware profile** CAP: Very Low (19) | OPP: Low (28) | MOT: Very Low (16)

|           | CAP<br>Very Low (19) | OPP<br>Low (28) | MOT<br>Very Low (16) |
|-----------|----------------------|-----------------|----------------------|
| Very High |                      |                 |                      |
| High      |                      |                 |                      |
| Moderate  |                      |                 |                      |
| Low       |                      | 28              |                      |
| Very Low  | 19                   |                 | 16                   |

Blank template version: practitioners print the chart with no bands filled and write the scores by hand during a scoring session, then shade the active cells. The blank template is always the same table with no fill data supplied; the chart renders with ghost-white cells throughout and no score values, which serves as the paper form.

# Visualization 2: Team Composition Overview

Two coordinated sub-charts: persona count bar (left) and dimension band distribution (right), rendered side by side for a complete population snapshot.

The Team Composition Overview answers two questions simultaneously. The left chart, a horizontal count bar, answers: which personas are present in this team, and in what proportion? Each persona gets one row; the bar length is proportional to the count, and the percentage label appears after the bar. The right chart, a stacked band distribution bar, answers the question: across the team as a whole, how concentrated is each dimension at each band level? Each dimension (CAP, OPP, MOT) gets one row; within that row, segments of different colors represent the count of team members at each band from Very Low (dark red, leftmost) to Very High (deep blue, rightmost).

The two charts are designed to be read together. If the persona chart shows a high Compliant count and the band distribution chart shows a strong OPP-High concentration but MOT-Low concentration across the team, that is the expected pattern: the Compliant profile is produced by exactly that combination. If the persona chart shows multiple Skeptics but the band distribution shows MOT concentrated only in the Low band rather than spanning Low-to-Moderate, that signals the Skeptic classification may be masking some Resistant-boundary profiles that deserve closer review.

## Persona Distribution

| Persona    | Team count |     |
|------------|------------|-----|
| Skeptic    | 2          |     |
| Enthusiast | 1          | 13% |
| Compliant  | 2          |     |
| Unaware    | 1          | 13% |
| Resistant  | 1          | 13% |
| Embedded   | 1          | 13% |

## Dimension Band Distribution

| Dim. | Band distribution (Very Low → Very High) |   |   |  |  |
|------|------------------------------------------|---|---|--|--|
| CAP  | 1                                        | 5 | 2 |  |  |
| OPP  | 2                                        | 3 | 3 |  |  |
| MOT  | 2                                        | 4 | 2 |  |  |

Very Low

Low

Moderate

High

Very High

### Reading the demo team at a glance:

Persona distribution: Skeptic is the modal persona (2 members), followed by Compliant (2 members). Embedded and Enthusiast are present as single individuals, and Unaware and Resistant each appear once. The team has no persona-level void, which is an important starting condition. This team's Embedded member is High, not Very High, on all three dimensions, so the Exemplar sub-flag (D3, Rule 2a) does not apply; the

persona count bar reports this developer as plain "Embedded," with no visual distinction from an Exemplar case unless the count label is annotated. When a future assessment cycle does produce a uniformly Very High Embedded profile, annotate that row "Embedded (Exemplar)" in the count bar rather than adding a new bar segment; it is a label refinement on the existing Embedded count, not a seventh persona, and it signals which Embedded developer to prioritize first for the formal champion or mentor role (D6).

Dimension distribution: OPP spans High and Moderate/Low almost equally, reflecting the two Compliers (High OPP) sitting alongside the two Skeptics, the Resistant (Moderate OPP), and the Enthusiast (Low OPP). MOT is the most homogeneous dimension, concentrated in Low and Very Low, suggesting team-wide motivational poverty that individual OPP-driven interventions alone will not resolve.

The most actionable aggregate signal, MOT-Low, is the dominant band across the team. An intervention that only improves organizational opportunity (OPP) without addressing motivation will benefit the Compliers and Enthusiasts but will leave the Skeptics, Resistant, and Unaware largely unchanged.

*Demonstrated with the 8-person demo team before and after a 6-month targeted organizational opportunity intervention.*

The most important information the table encodes is not the magnitude of composite score change but the shape of change. An Enthusiast who shifts from Low OPP to Moderate OPP and transitions to Embedded represents a qualitatively different outcome, a confirmed persona transition, from a Skeptic who gains 5 composite points without changing any dimension band. Both are positive results, but they warrant different follow-up actions and signal different things about what the intervention actually affected.

## PRE-INTERVENTION

## POST-INTERVENTION

*Delta values show change in normalized score (0-100 scale). Persona transition cells are color-coded to the new persona. Five blank rows are provided below the data section for teams larger than 8 or for new members added during the tracking period.*

| Team Member | Pre-Persona | Post-Persona | Pre Composite | Post Composite | CAP Change | OPP Change | MOT Change | Trend | Notes / Next review                                                         |
|-------------|-------------|--------------|---------------|----------------|------------|------------|------------|-------|-----------------------------------------------------------------------------|
| Dev-01      | Embedded    | Embedded     | 84            | 87             | 0          | +1         | +1         | ▲ +3  | Stable. Expanded to security champion role.                                 |
| Dev-02      | Enthusiast  | Embedded     | 62            | 79             | +1         | +3         | +1         | ▲ +17 | OPP improved after champion introduction. Transition to Embedded confirmed. |

| Team Member | Pre-Persona | Post-Persona | Pre Composite | Post Composite | CAP Change | OPP Change | MOT Change | Trend | Notes / Next review                                                                                |
|-------------|-------------|--------------|---------------|----------------|------------|------------|------------|-------|----------------------------------------------------------------------------------------------------|
| Dev-03      | Compliant   | Compliant    | 56            | 61             | 0          | 0          | +1         | ▲ +5  | Small MOT gain. Still Compliant; intrinsic motivation work needed.                                 |
| Dev-04      | Skeptic     | Skeptic      | 48            | 52             | 0          | +1         | +1         | ▲ +4  | Marginal gains. Needs evidence-based persuasion on ROI.                                            |
| Dev-05      | Skeptic     | Compliant    | 51            | 58             | 0          | +2         | 0          | ▲ +7  | OPP gains pushed this into the Compliant range. MOT unchanged.                                     |
| Dev-06      | Resistant   | Resistant    | 45            | 44             | 0          | -1         | 0          | ▼ -1  | No improvement. OPP slight decline. Autonomy-preserving approach not yet tried.                    |
| Dev-07      | Unaware     | Unaware      | 21            | 33             | +1         | +1         | +1         | ▲ +12 | Early progress on CAP, foundational training landed. Still Unaware but the trajectory is positive. |
| Dev-08      | Compliant   | Compliant    | 53            | 56             | 0          | 0          | +1         | ▲ +3  | Steady. Parallel to the Dev-03 pattern.                                                            |
|             |             |              |               |                |            |            |            |       |                                                                                                    |
|             |             |              |               |                |            |            |            |       |                                                                                                    |
|             |             |              |               |                |            |            |            |       |                                                                                                    |
|             |             |              |               |                |            |            |            |       |                                                                                                    |
|             |             |              |               |                |            |            |            |       |                                                                                                    |

#### What the demo team's longitudinal data shows:

The OPP-focused intervention (security champion introduction + dedicated security time allocation) produced a confirmed persona transition in one developer (Dev-02: Enthusiast → Embedded) and a partial shift in another (Dev-05: Skeptic → Compliant). It had no measurable effect on the Resistant developer (Dev-06) and only early-stage movement for the Unaware developer (Dev-07).

The pattern is consistent with D3's decision rule rationale: Enthusiasts are the most responsive to OPP interventions because CAP and MOT are already in place; Resistant developers require autonomy-preserving approaches that an OPP-focused intervention does not provide; Unaware developers need foundational capability work before opportunity improvements can land.

The appropriate next intervention cycle, based on this data, is a MOT-targeted program (evidence-based persuasion for Skeptics, autonomy-design for Resistant) combined with continued CAP support for Unaware. The OPP intervention should be maintained; removing it would likely reverse the Compliant gains, but it should not be the primary investment vehicle in cycle 2.

# SECUR-E Visualization 4 - Five Automated Insight Triggers

Automated insight triggers are conditional rules that fire when a profile pattern warrants special attention beyond the standard persona classification. They are called 'automated' because, in a digital deployment of the scoring system, they would be evaluated algorithmically as part of the scoring pipeline. In the current paper-based implementation, they function as a practitioner checklist: after completing D3 classification, the practitioner runs through each trigger condition and notes which fire.

Each trigger is anchored to specific DASP drivers and their qualitative evidence. The triggers are not arbitrary rules; each one captures a pattern that the primary research literature identifies as either a high-risk behavioral state or a high-opportunity intervention window. A trigger that fires should be treated as a priority signal that overrides or refines the standard intervention approach recommended in D6.

## T1 Enthusiast Burnout Risk

*Applies to: Enthusiast*

| Trigger condition                                                                                                                           | What it signals                                                                                                                                                                                                                                                                                                                                                                                                   | Recommended action                                                                                                                                                                                                                                                                                                                     | Evidence anchor                                                                             |
|---------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------|
| Persona = Enthusiast AND OPP $\leq$ 25 (normalized) AND MOT $\geq$ 75 (normalized) AND Reflection-3 names a specific organizational deficit | The developer is sustaining high security engagement in an environment that actively under-supports it. SECUR-E is explicit that this creates fragility: 'if the organizational context remains unsupportive, Enthusiast behavior is unlikely to persist.' The longer this gap persists, the higher the risk of motivational exhaustion and disengagement, and of losing the team's most valuable security asset. | Priority: close the OPP gap before addressing anything else. Assign a security champion contact. Allocate dedicated security time. Connect the developer to a peer network. Do not increase security demands without first improving support. If Reflection-3 identifies a specific deficit, address it directly and in the near term. | DASP D3 (security champion role). DASP D2 (dedicated time as a core driver of opportunity). |

## T2 Compliant Fragility Risk

*Applies to: Compliant, Skeptic/Compliant borderline*

| Trigger condition                                                                                         | What it signals                                                                                                                                                                                                                                                                      | Recommended action                                                                                                                                                                                                                                                                    | Evidence anchor                                                                              |
|-----------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------|
| Persona = Compliant AND MOT $\leq$ 30 (normalized) AND OPP is primary driver (OPP $\geq$ MOT + 30 points) | Security behavior is almost entirely externally regulated. The Compliant developer follows security procedures when they are enforced, but has no intrinsic motivation to do so. This creates a single point of failure: if organizational enforcement weakens (policy changes, team | Design a transition intervention that builds intrinsic motivation without prematurely removing extrinsic enforcement. DASP D15 (security benefits) and D16 (customer-protection mindset) are the primary levers. Do not interpret stable Compliant behavior as success; track whether | DASP D8 (automatic motivation as destination). Tyler & Blader (2005) internalization theory. |

|  |                                                                                                                                                                                 |                                                                                                                       |  |
|--|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------|--|
|  | restructuring, reduced audit frequency), security behavior will drop sharply. DASP captures this directly: 'that's what the process requires' as the sole behavioral rationale. | MOT scores are moving over time. If MOT remains static across two assessment cycles, escalate intervention intensity. |  |
|--|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------|--|

## T3 Undifferentiated Low - Systemic Risk

*Applies to: All personas - team-level trigger*

| Trigger condition                                                                                                                       | What it signals                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       | Recommended action                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                | Evidence anchor                                                                                                                                                                 |
|-----------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p>&gt; 40% of team members have ALL three dimensions in Low or Very Low bands<br/>OR Mean OPP (normalized) &lt; 35 across the team</p> | <p>This trigger fires on team-level data, not individual profiles. It indicates a systemic organizational failure rather than individual gaps. When more than 40% of a team scores low across all three dimensions, or when the mean opportunity score is very low, the cause is almost certainly environmental, an inadequate security culture, the absence of champions, or a lack of policy support, rather than a collection of individual capability or motivation failures. Treating this as an individual-level problem with individual-level interventions will not work.</p> | <p>Escalate beyond the team level. The trigger requires an organizational-level response: security culture assessment, management mandate, dedicated security staffing, or structural changes to the development process. Document the trigger in any stakeholder report. Refer to DASP D1 (organizational security culture) and D6 (social perception of security) as the primary intervention targets. Do not start individual persona-based interventions until at least one organizational structural change is in place.</p> | <p><b>DASP D6</b> (cited by 23/28 practitioners as the primary driver of social opportunity). <b>DASP D1</b> (culture as the root enabler of all other security behaviors).</p> |

## T4 Resistant Escalation Risk

*Applies to: Resistant*

| Trigger condition                                                                                                                                                | What it signals                                                                                                                                                                                                                                                                                                                                                                                                                                                                            | Recommended action                                                                                                                                                                                                                                                                                                                                                                                                                                                                           | Evidence anchor                                                                                          |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------|
| Persona = Resistant AND MOT-3 (item 19) $\geq 4$ AND MOT-7 (item 23) $\geq 4$ AND Reflection-1 contains explicitly negative language about security requirements | Two highly scored reactance items, combined with negative language in the open reflection, indicate that the Resistant developer has moved beyond mere disengagement to active opposition. SECUR-E identifies this as the hardest sub-profile to shift: 'psychological reactance; they view security processes as adversaries to productivity.' Applying increased enforcement or compliance pressure at this stage will deepen reactance rather than reduce it, as Brehm (1966) predicts. | Switch from compliance-framed to autonomy-framed security approaches immediately. Remove the developer from mandatory security training tracks if possible; this reduces the perception that security is being imposed. Replace with optional, developer-controlled security activities (CTF participation, security book club, tool evaluation roles). Involve the developer in security decision-making. This trigger is a signal to pause any coercive intervention, not to intensify it. | DASP D20 ( <i>autonomy in security practices</i> ). Brehm (1966) <i>psychological reactance theory</i> . |

## T5 Transition Opportunity - Compliant Pathway to Embedded

*Applies to: Compliant (transitional)*

| Trigger condition                                                                                                                                          | What it signals                                                                                                                                                                                                                                                                                                                                                                                                                                                              | Recommended action                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      | Evidence anchor                                                                                                     |
|------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------|
| Persona = Compliant AND MOT 40-65 (normalized) AND MOT-4 (item 20) $\geq 3$ (some unprompted security action) AND Reflection-2 contains a positive example | This is the only trigger that fires as a positive signal rather than a risk flag. It identifies a Compliant developer who has begun developing intrinsic motivation; the MOT score is higher than the standard Compliant pattern, and item 20 (acting on security without prompting) scores above neutral. SECUR-E exemplifies this transition: a developer who started Compliant and was actively moving toward Embedded, driven by a combination of organizational support | This developer is in the highest-leverage state for a motivation-building intervention. Act now. DASP D8 (automatic motivation development) and D15 (building genuine belief in security value) are the primary intervention tools. Assign increasing responsibility and autonomy, a code review security lead role, and contributions to internal security standards. Mark for re-assessment at 3 months rather than the standard 6. If the transition to Embedded completes, this developer becomes a | DASP D8 ( <i>automatic motivation as the destination state</i> ). SDT <i>intrinsic motivation internalization</i> . |

|  |                                  |                                       |  |
|--|----------------------------------|---------------------------------------|--|
|  | and growing personal investment. | candidate for future champion status. |  |
|--|----------------------------------|---------------------------------------|--|

### How to use the insight triggers in practice

After completing the persona classification for each team member (D3), run through each trigger condition sequentially. A trigger fires if its condition is met. Record which triggers fire and for which developers on the team grid (D4, Grid A).

Triggers take priority over standard intervention recommendations (D6). If T4 fires for a Resistant developer, the D6 recommendation for Resistant developers should be modified to remove any enforcement-based elements before deployment. If T5 fires for a Compliant developer, the D6 recommendation should be escalated in urgency and scope.

Not all triggers will fire for every team or every assessment cycle. A team with no Enthusiasts cannot trigger T1. A team with no Resistant developers cannot trigger T4. Triggers that do not fire should be noted as 'not applicable' rather than left blank, to demonstrate that the check was performed.

The five triggers together cover the three most dangerous individual-level risk states (T1 Enthusiast fragility, T2 Compliant fragility, T4 Resistant escalation), one systemic organizational risk state (T3), and one positive opportunity state (T5). They are not exhaustive; practitioners who identify recurring patterns not captured here should document and add local triggers calibrated to their organizational context.